

TryHackMe

Defensive Security Intro

Learning Notes & Key Concepts

"Preventing, detecting, and responding — the three pillars of defensive security."

1. What Is Defensive Security?

Defensive security is the practice of protecting systems, networks, and data from cyber threats. While offensive security focuses on finding vulnerabilities by thinking like an attacker, defensive security focuses on building resilient defences, detecting intrusions, and responding to incidents effectively.

The Two Core Tasks of Defensive Security

1. Preventing intrusions from occurring in the first place. 2. Detecting intrusions when they occur and responding appropriately to minimize damage.

Blue Team vs. Red Team

Professionals who practice defensive security are known as the Blue Team. They are counterparts to the Red Team (offensive security). Together, both teams ensure an organization is hardened against real-world threats.

Blue Team (Defensive)	Red Team (Offensive)
Monitors and protects systems	Simulates attacks on systems
Detects and responds to threats	Finds and exploits vulnerabilities
Focuses on prevention and recovery	Focuses on penetration and compromise
Uses SIEM, IPS, Firewalls	Uses exploit frameworks, scanners

Foundational Defensive Practices

- **User Cyber Security Awareness:** Training users to recognize threats like phishing — humans are often the weakest link.
- **Asset Documentation & Management:** Knowing what systems and devices exist is essential to protect them properly.
- **Updating & Patching Systems:** Computers, servers, and network devices must be patched against known vulnerabilities.
- **Preventative Security Devices:** Firewalls control traffic; Intrusion Prevention Systems (IPS) block attacks matching known signatures.
- **Logging & Monitoring:** Without logs, detecting malicious activity or unauthorized devices on the network is impossible.

2. Security Operations Center (SOC)

A Security Operations Center (SOC) is a centralized team of cybersecurity professionals who monitor an organization's network and systems around the clock to detect, analyze, and respond to malicious events. The SOC is the frontline of an organization's defensive posture.

What a SOC Monitors

The SOC has four primary areas of focus:

Focus Area	Description
Vulnerabilities	When a weakness is found in a system, it must be patched immediately. If no patch exists, mitigations must be applied to prevent exploitation.
Policy Violations	Security policies define rules for protecting the network. Violations — like uploading confidential data to unauthorized cloud services — must be detected.
Unauthorized Activity	If an attacker steals login credentials and accesses the network, the SOC must detect and block this as quickly as possible.
Network Intrusions	Even well-defended networks can be breached. The SOC must detect intrusions — whether via phishing, exploits, or other vectors — before damage escalates.

3. Threat Intelligence

Threat intelligence is the process of gathering, processing, and analyzing information about potential and active adversaries. The goal is to enable a threat-informed defense — knowing

who your adversaries are allows you to anticipate and counter their moves before an attack occurs.

Why Threat Intelligence Matters

Different organizations face different adversaries. A mobile operator may face data-stealing criminals; a petroleum refinery may face nation-state actors. Knowing your adversary helps you prioritize defences correctly.

The Threat Intelligence Lifecycle

Phase	Activity	Detail
1	Collect	Data is gathered from internal sources (network logs) and external sources (public forums, threat feeds, dark web monitoring).
2	Process	Raw data is organized and normalized into a format suitable for analysis — removing noise and structuring key indicators.
3	Analyze	Processed data is analyzed to identify adversary patterns, motives, TTPs (Tactics, Techniques & Procedures), and to produce actionable recommendations.
4	Disseminate	Intelligence is shared with relevant teams — SOC analysts, incident responders, and leadership — to inform response strategy.

Key Outcome of Threat Intelligence

- **Identify the Threat Actor:** Know who is targeting your organization — nation-state, criminal group, insider, etc.
- **Understand Adversary TTPs:** Know their tactics, techniques, and procedures to anticipate attack methods.
- **Predict Activity:** Use intelligence to forecast likely attack vectors before they are used.
- **Prepare a Response Strategy:** Create playbooks and mitigations tailored to your specific threat landscape.

4. Digital Forensics & Incident Response (DFIR)

DFIR encompasses two related but distinct disciplines: Digital Forensics (investigating what happened) and Incident Response (managing and recovering from the event). Together they form the backbone of how organizations respond to security breaches.

4.1 Digital Forensics

Digital forensics applies scientific investigation methods to digital systems. In defensive security, it focuses on analyzing evidence of attacks, attributing them to perpetrators, and uncovering the full scope of a breach. Forensic investigators examine four key evidence sources:

Evidence Source	What It Reveals
File System	A low-level disk image reveals installed programs, created/modified/deleted files, and partially overwritten data — a rich forensic record.
System Memory	If malware runs entirely in memory (fileless malware), a RAM image is the only way to capture and analyze it — critical for advanced threat investigations.
System Logs	Every client and server logs its activities. Even if attackers attempt to erase traces, residual log entries often remain as evidence.
Network Logs	Packet captures and flow logs reveal whether an attack occurred, what data was exfiltrated, and what external systems were contacted.

4.2 Incident Response

Incident response is the structured methodology for handling a cyber attack or breach. The goal is to minimize damage and recover operations as quickly as possible. Every organization should have an Incident Response Plan (IRP) prepared before an incident occurs.

The four major phases of incident response:

#	Phase	Activities
1	Preparation	Train an incident response team. Establish policies, playbooks, and detection tools. Implement preventative controls to minimize incident likelihood.
2	Detection & Analysis	Use monitoring tools to detect incidents. Analyze their scope, severity, and nature. Triage alerts to prioritize the most critical threats.
3	Containment, Eradication & Recovery	Stop the incident from spreading (contain). Remove the threat entirely (eradicate). Restore systems to normal operation (recover).
4	Post-Incident Activity	Write a post-incident report. Identify lessons learned. Update playbooks and controls to prevent recurrence of the same attack.

4.3 Malware Analysis

Malware (malicious software) is one of the primary tools attackers use. Malware analysis is the process of studying malicious programs to understand their behavior, capabilities, and impact — enabling defenders to build better detections and protections.

Common Malware Types

- **Virus:** Code that attaches to legitimate programs and spreads between computers by altering, overwriting, and deleting files — ranging from slowdowns to complete system failure.
- **Trojan Horse:** A program that appears legitimate but secretly executes malicious functions — such as granting an attacker full remote control over the victim's system.
- **Ransomware:** Encrypts the victim's files and demands a ransom payment in exchange for the decryption key — one of the most financially damaging forms of malware today.

Analysis Techniques

- **Static Analysis:** Inspecting the malware's code without executing it. Requires knowledge of assembly language and binary analysis. Reveals the program's structure and intended behavior.
- **Dynamic Analysis:** Running the malware in a safe, isolated environment (sandbox) and observing its behavior — network connections made, files modified, processes created, registry changes.

5. SIEM — Security Information & Event Management

A SIEM (Security Information and Event Management) system is a central platform that aggregates, correlates, and analyzes security data from across an organization's infrastructure in real time. It is the primary tool used by SOC analysts to detect and investigate threats.

How SIEM Works

SIEM collects log data from firewalls, servers, endpoints, and applications. It correlates events across sources to identify patterns that indicate a threat — such as a login from an unusual location at 3 AM followed by mass file access.

The SIEM Lab — Hands-On Exercise

The TryHackMe room provided a simulated SIEM environment to practice real-world SOC analysis. The scenario unfolded as follows:

#	Step	What Happened
---	------	---------------

1	Alert Triggered	The SIEM flagged a suspicious login attempt from an unknown IP address at 3 AM — an unusual time and location for normal user activity.
2	IP Investigation	The analyst used a threat intelligence tool to look up the flagged IP. The tool confirmed it was a known malicious address with prior reported activity.
3	Escalation	The finding was escalated to the SOC lead for a decision on blocking — following proper authorization procedures.
4	Remediation	The SOC lead approved blocking the IP. A new firewall rule was created to block all incoming traffic from that address.
5	Flag Captured	Completing the exercise revealed the flag: THM{THREAT-BLOCKED}, confirming the full detection-response cycle was completed.

6. Key Takeaways & Lessons Learned

Defence Requires Both Prevention and Detection

No security control is 100% effective. Preventative measures (firewalls, patching) reduce the attack surface, but detection and response capabilities ensure that when a breach does occur, it is caught and contained quickly.

Context Is Everything in SOC Work

A single alert means very little without context. SOC analysts must correlate events across multiple systems — a failed login becomes significant when combined with a geo-anomaly and subsequent file access at an unusual hour.

Threat Intelligence Drives Proactive Defence

Reactive security — waiting for an alarm to go off — is insufficient against sophisticated attackers. Threat intelligence moves defenders from reactive to proactive, allowing them to anticipate and prepare for adversary TTPs before attacks occur.

Forensics Reveals the Full Story

Post-incident forensics is not just about finding what went wrong — it reveals the full attack chain, the attacker's methods, and what data was affected. This evidence is critical for legal proceedings and for improving future defences.

Malware Analysis Builds Better Detections

Understanding how malware behaves — what files it touches, what connections it makes, how it persists — directly informs the creation of detection signatures and behavioral rules in SIEM and endpoint protection tools.

Humans Remain the Weakest Link

Technical controls only go so far. Social engineering, phishing, and credential theft bypass even well-configured systems. Continuous user security awareness training is as critical as any technical security tool.

7. Defensive Security Career Paths

The TryHackMe room highlights several career pathways in defensive security. Each role plays a critical part in protecting an organization:

Role	Core Responsibility	Key Skill
SOC Analyst (Tier 1–3)	Monitor SIEM alerts, triage events, escalate confirmed incidents	Alert analysis, threat triage
Threat Intelligence Analyst	Gather and analyze adversary data to inform defensive strategy	OSINT, TTP mapping, CTI feeds
Digital Forensics Analyst	Investigate security incidents and produce evidence-based reports	Disk/memory forensics, log analysis
Incident Responder	Lead containment, eradication, and recovery during active breaches	Incident handling, crisis management
Malware Analyst	Reverse-engineer malicious software to understand and counter it	Assembly, sandboxing, reverse engineering
Security Engineer (Blue)	Design and maintain security controls, SIEM rules, and monitoring	Architecture, automation, detection engineering

8. Recommended Next Steps

Completing the Defensive Security Intro room is your entry point. Here is a progression path to build deeper skills:

- **Immediate:** Complete TryHackMe's Introduction to Cyber Security learning path.
- **Foundations:** Study the Introduction to SIEM room and Security Operations room on TryHackMe.

- **Intermediate:** Work through SOC Level 1 path: log analysis, Wireshark, Splunk, and threat hunting.
- **Certifications:** CompTIA Security+, CompTIA CySA+ (Cybersecurity Analyst), and Blue Team Labs certifications.
- **Advanced Practice:** Practice on Blue Team Labs Online (BTLO) and LetsDefend for real-world SOC scenarios.
- **Professional:** Work toward GIAC GCIH (Incident Handler) or GIAC GCFE (Forensic Examiner) for professional recognition.

Remember: Consistency Is Everything

Cyber threats evolve daily. The best defenders are continuous learners — reading threat intelligence feeds, practicing in labs, and studying real-world incidents. Build the habit of daily practice and you will be well-prepared for a career in defensive security.

Summary

Topic	One-Line Summary
Defensive Security	Prevent, detect, and respond to threats — the complement to offensive security.
Blue Team	Cybersecurity defenders who monitor, protect, and respond to threats.
SOC	24/7 team monitoring networks for vulnerabilities, policy violations, unauthorized access, and intrusions.
Threat Intelligence	Gather, analyze, and act on adversary information to enable proactive defence.
Digital Forensics	Scientifically investigate attacks using file systems, memory, logs, and network captures.
Incident Response	Four-phase process: Prepare → Detect & Analyze → Contain & Recover → Post-Incident Review.
Malware Analysis	Static (code inspection) and dynamic (sandbox execution) analysis to understand malware behavior.
SIEM	Centralized platform aggregating and correlating security events to surface real threats from noise.

Source: TryHackMe — Defensive Security Intro Room | tryhackme.com